



ISC 互联网安全大会



360 互联网安全中心

点亮你的火把 网络安全人才培养点滴感悟

段海新 教授

清华大学-360企业安全联合研究中心

2018 ISC 互联网安全大会 中国·北京

Internet Security Conference 2018 Beijing·China

(原中国互联网安全大会)

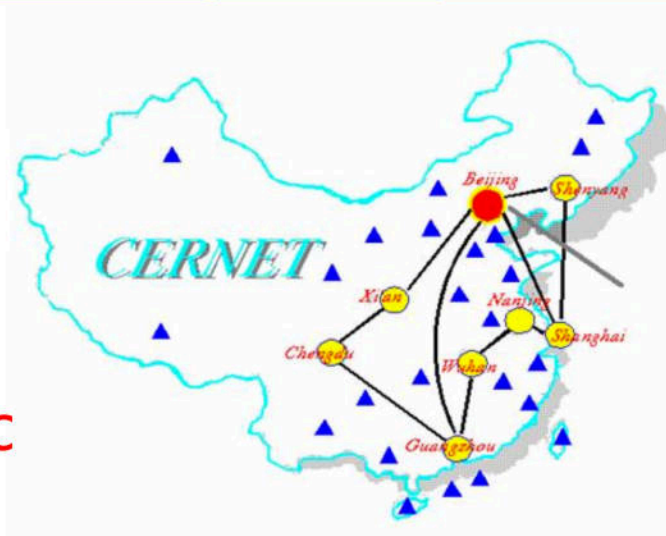
央视《我是黑客》——聚似一团火，散若满天星



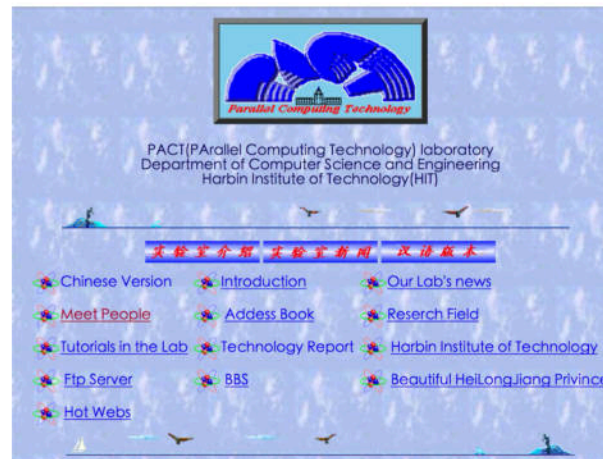
- 自由探索与开放合作的经历
- 几个学术研究的案例
- 研究方法和创新的体会

我学生时代的自由探索

- 中国互联网和CERNET1994
- 把我带入互联网研究的两次报告
 - 刚回国的李晓明、李星教授
 - Across the Great Wall, we can reach every c
 - 中国连接世界vs互联网进入中国



- 90年代初的自由探索
 - Linux, TCP/IP, SMTP, HTTP
 - Mosaic/Httpd/CGI/MySQL/Java



一起探索小伙伴，或成为终身合作者

- 李康，现美国Georgia University 教授
 - 曾经清华网络中心助研博士生
 - Disekt CTF战队创始人, 进入美国CGC决赛
 - 介绍我和学生参加了CTF 国际竞赛
- 陈硕，现微软研究院资深研究员
 - 1997-2000清华网络中心硕士生，助研
 - 在UIUC 研究容错的团队中研究安全
 - 许多论文在网络安全领域很有影响力



“误入”安全圈的几个非典型的学生

- 杨坤，清华博士生，蓝莲花队长

- 电子系转到计算机系
- 伯克利访问，参加CGC项目
- 长亭科技联合创始人首席科学家
- 世界漏洞挖掘比赛Pwn2wn 第三



- 郑晓峰，清华大学研究生

- 换导师来到我实验室
- GeekPwn 2015第一（46万奖金）
- USENIX Sec' 15, NDSS' 16 最佳论文



全球攻防对抗赛DEF COF资格赛、决赛

王若愚，美国UCSB, Shellphish战队





**美国国防部DARPA Cyber Grand Challenge
机器自动攻防超级挑战赛，5000多万美元，2年**

CGC七支决赛队伍3个有我们的成员



张超、李康在INFORSEC作报告@清华



人工智能在漏洞挖掘等安全领域中的应用现状及前景展望

李康

美国乔治亚大学教授
360人工智能安全研究院院长



机器的崛起
——拥抱自动化安全攻防时代的到来

张超

清华大学网络科学与网络空间安全研究院副教授
清华大学-360企业安全研究中心副主任



王若愚介绍CGC的经历 INFORSEC@清华





网络安全研究国际学术论坛

International Forum For Security Research

[Home](#) [SecTalk](#) [SecComm](#) [视频直播](#) [业界动态](#) [论坛简介](#) [欢迎投稿](#)

« 带你走进维也纳版的CCS2016 (现场报告点评四) » [带你走进维也纳版的CCS2016 \(现场报告点评五\) »](#)

【视频回看】UC Santa Barbara博士生王若愚: Shellphish CGC背后的故事

By Jin Gao | November 22, 2016 | [视频直播](#)

Cyber Grand Challenge 决赛于今年八月份在美国拉斯维加斯成功举办。来自美国 UC Santa Barbara 的 Shellphish 团队在决赛中拿到了第三名, 获得了七十五万美元奖金。作为 Shellphish CGC 团队的一员, 王若愚在此次报告中详细介绍 Shellphish CGC 团队的研究成果、技术实现和团队里不为外人所知的奇闻异事。此外, 他介绍二进制程序分析平台 angr, 以及如何在科研和 CTF 竞赛中使用 angr 来迅速解决问题。

Title: Shellphish CGC背后的故事

Speaker: 王若愚 UC Santa Barbara博士生

Time: 2016年11月17日

视频目录:

- [第1部分 前言](#)
- [第2部分 CGC是什么? 网络安全挑战赛介绍 \(上\)](#)
- [第3部分 网络安全挑战赛介绍 \(下\)](#)
- [第4部分 什么是Mechanical Phish及其核心技术](#)



Shellphish 所开发的自动攻防系统mechanical Phish已经开源, 国内已经有几个团队基于此开展研究



Mechanical Phish

@shellphish's Cyber Reasoning System for the DARPA Cyber Grand Challenge

[Santa Barbara](#) cgc@shellphish.net

<https://github.com/mechaphish>

目录



ISC 互联网安全大会

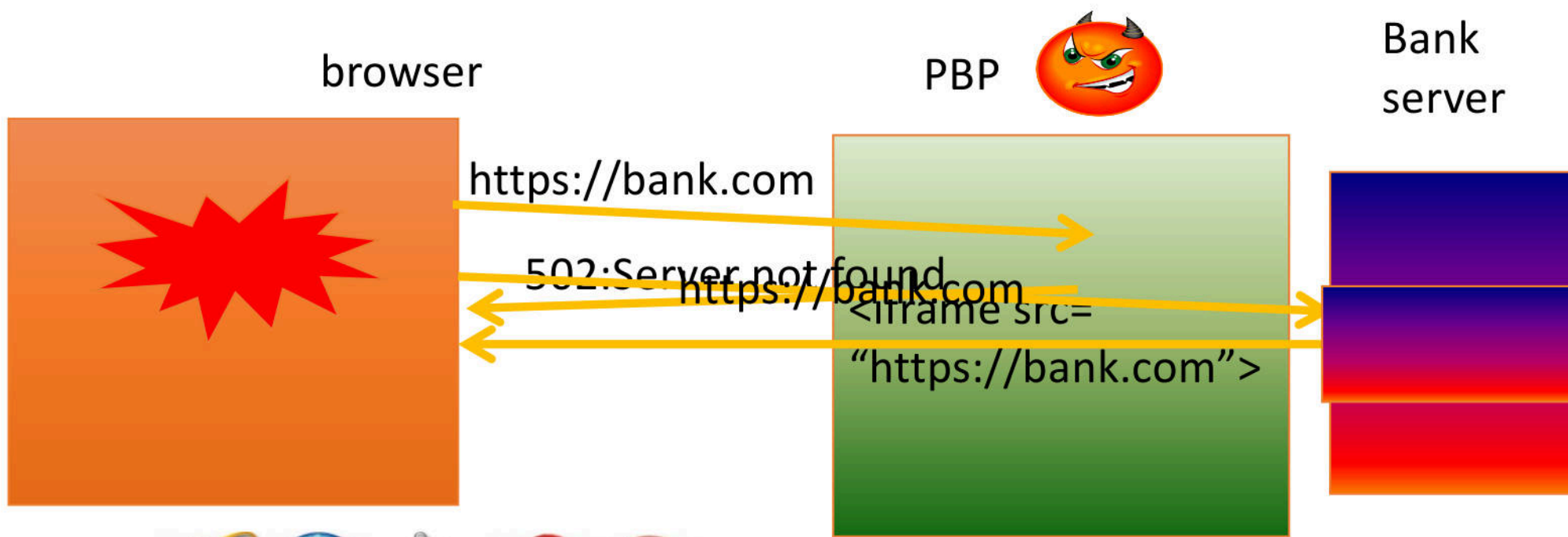


360 互联网安全中心

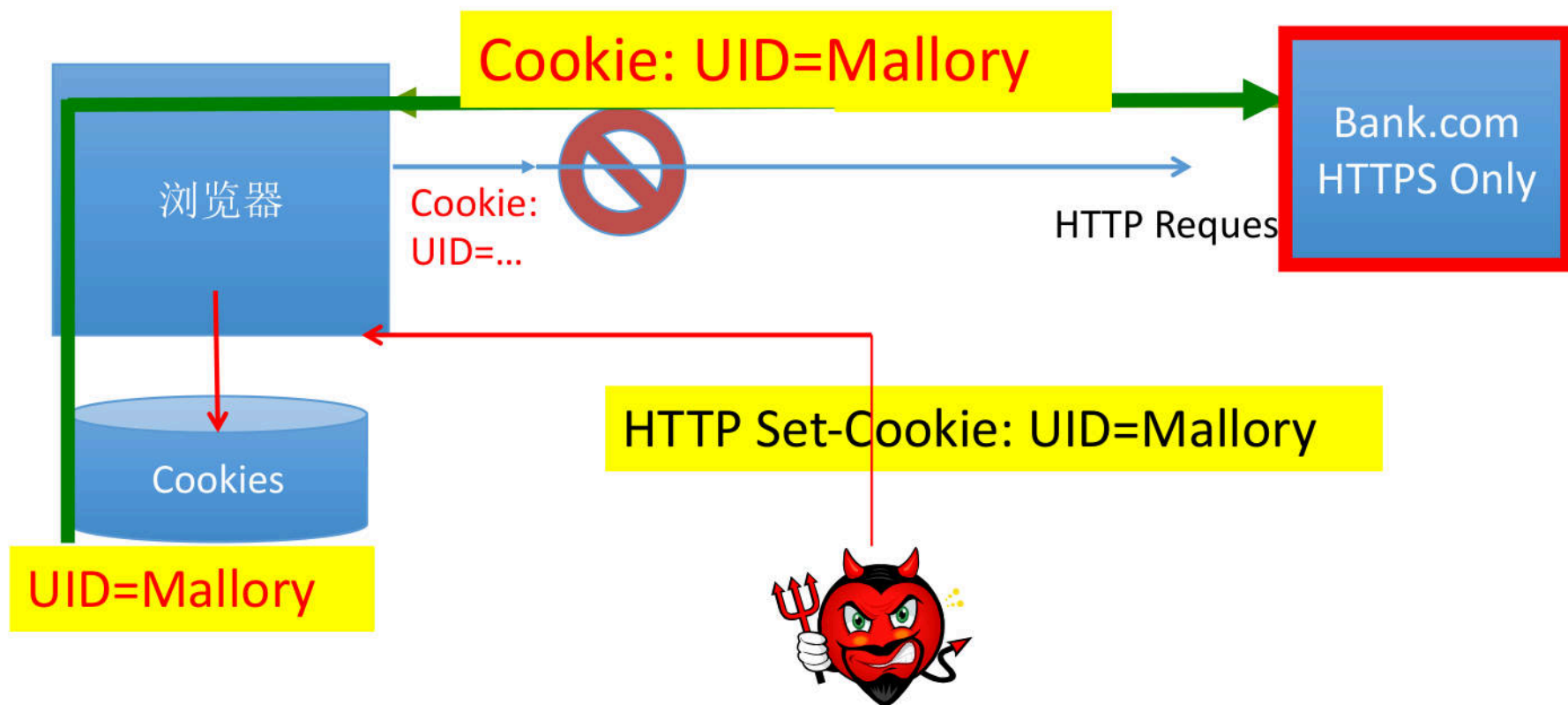
- 自由探索与开放合作的经历
- ▶ • 几个学术研究的案例
- 研究方法和创新的体会

• 攻击场景之一

- Proxy's error page: e.g., 502-server-not-found, other 4xx/5xx response;
- Script in error page runs in `https://bank.com`.

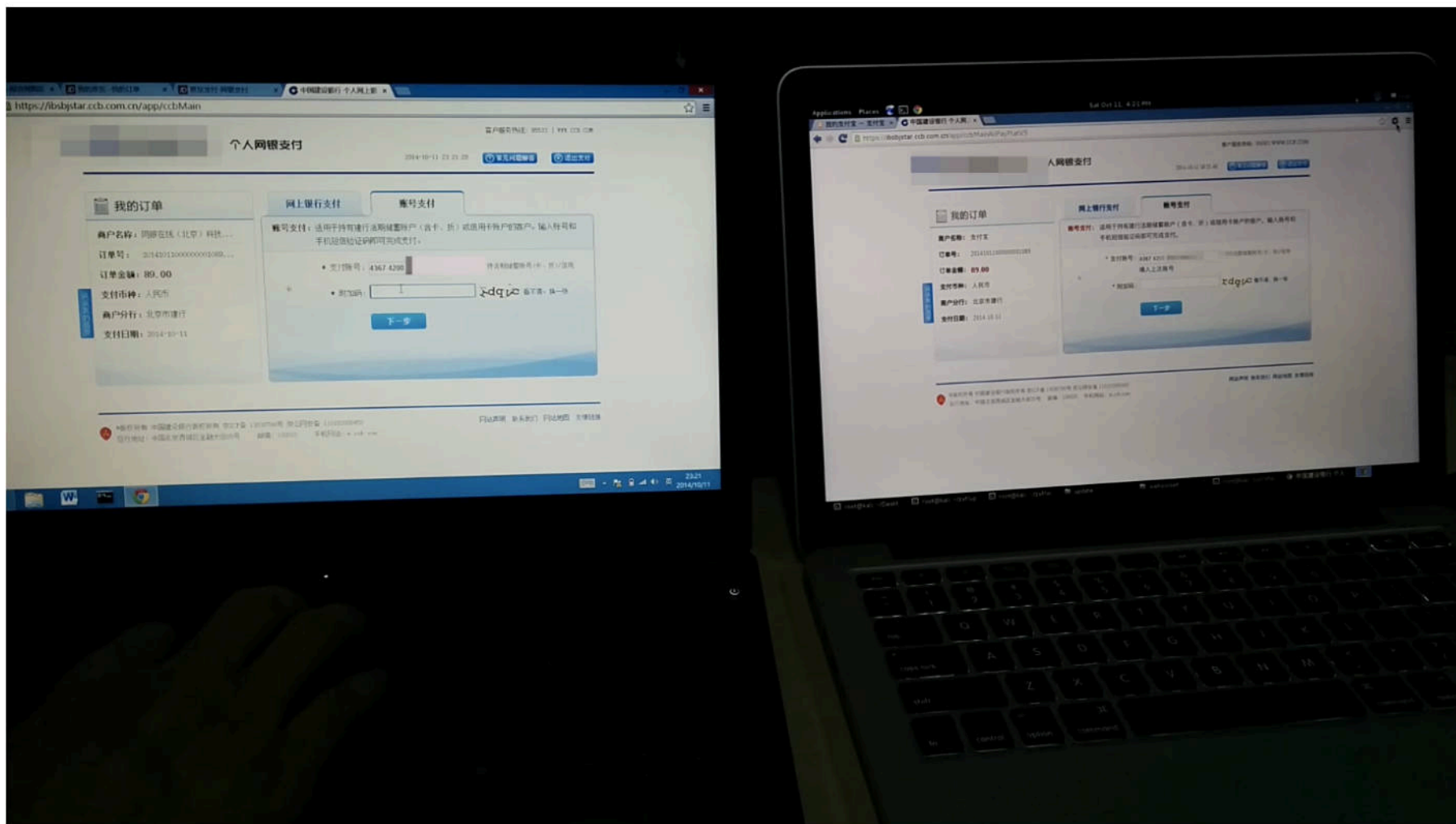


郑晓峰, Cookies Lack Integrity, USENIX'15



郑晓峰 (走马)
清华大学毕业,
360企业安全集团研
究员

演示：谁动了你的电子钱包



替换Gmail的好友

- Injecting cookies into HTTPS can cause serious attacks such as account hijacking



Replace your friend list in Gmail/Gtalk with hackers

我们测试证明受影响的网站和浏览器



ISC 互联网安全大会



360 互联网安全中心



郑晓峰、杨坤等获GEEKPWN15第一、三，共78万奖金



ZERO TRUST SECURITY 第三名：杨坤

第一名：郑晓峰等

美、日等政府应急响应组发布公告





Software Engineering Institute | Carnegie Mellon University



Homeland Security

Sponsored by the DHS Office of Cybersecurity and Communications

Vulnerability Notes Database

Advisory and mitigation information about software vulnerabilities

[DATABASE HOME](#) [SEARCH](#) [REPORT A VULNERABILITY](#) [HELP](#)

Vulnerability Note VU#804060

Cookies set via HTTP requests may be used to bypass HTTPS and reveal private information

Original Release date: 24 Sep 2015 | Last revised: 28 Oct 2015

[Print](#) [Tweet](#) [Send](#) [Share](#)

Overview

[RFC 6265](#) (previously RFC 2965) established HTTP State Management, also known as "cookies". In most web browser implementations of RFC 6265, cookies set via HTTP requests may allow a remote attacker to bypass HTTPS and reveal private session information.

Description

HTTP cookies have long been known to lead to potential security issues when managing HTTP state. For example, in [RFC 6265, Section 8.6](#):

Cookies do not provide integrity guarantees for sibling domains (and their subdomains). For example, consider foo.example.com and bar.example.com. The foo.example.com server can set a cookie with a Domain attribute of "example.com" (possibly overwriting an existing "example.com" cookie set by bar.example.com), and the user agent will include that cookie in HTTP requests to bar.example.com. In the worst case, bar.example.com will be unable to distinguish this cookie from a cookie it set itself. The foo.example.com server might be able to leverage this ability to mount an attack against bar.example.com.

as well as in [RFC 6265, Section 8.5](#):

Cookies do not provide isolation by port. If a cookie is readable by a service running on one port, the cookie is also readable by a service running on another port of the same server. If a cookie is writable by a service on one port, the cookie is also writable by a service running on another port of the same server.

...

Cookies do not provide isolation by scheme. Although most commonly used with the http and https schemes, the cookies for a given host might also be available to other schemes, such as ftp and gopher.

According to the researchers:

Quick Search

Advanced

View Notes By

- Date Published
- Date Updated
- CVSS

Report a Vulnerability

Please use the Vulnerability Reporting Form to report a vulnerability. Alternatively, you can email. Be sure to read our vulnerability disclosure policy.

Connect with Us

Subscribe to our feed

Read the CERT/CC blog



公開日: 2015/09/25 最終更新日: 2015/09/25

JVNVU#92999848

HTTP リクエスト経由で設定された Cookie によって HTTPS 接続がバイパスされたり情報漏えいが発生する問題

概要

[RFC 6265](#) (旧 RFC 2965) は、いわゆる Cookie による HTTP セッションの状態管理の仕組みを規定しています。RFC 6265 を実装しているほとんどのウェブブラウザでは、HTTP リクエストを通じて設定される Cookie によって、HTTPS 接続がバイパスされたり、セッション情報が取得されたりする問題が存在します。

影響を受けるシステム

詳細情報

Cookie を用いて HTTP セッションの状態管理を行う場合、様々なセキュリティ上の問題が発生する可能性があることが知られています。

例えば、[RFC 6265 の Section 8.6](#) には次のように記載されています。

Cookies do not provide integrity guarantees for sibling domains (and their subdomains). For example, consider foo.example.com and bar.example.com. The foo.example.com server can set a cookie with a Domain attribute of "example.com" (possibly overwriting an existing "example.com" cookie set by bar.example.com), and the user agent will include that cookie in HTTP requests to bar.example.com. In the worst case, bar.example.com will be unable to distinguish this cookie from a cookie it set itself. The foo.example.com server might be able to leverage this ability to mount an attack against bar.example.com.

(Cookie の設定では、隣接するドメインやサブドメインとの整合性は確保されない。例えば、foo.example.com と bar.example.com を考えてみよう。foo.example.com のサーバは Domain 属性 "example.com" の Cookie を設定することができる(bar.example.com のサーバが "example.com" の Cookie を設定していた場合には上書きされる)。この状態で bar.example.com にアクセスすると、foo.example.com によって上書きされた Cookie がサーバに送られることになる。bar.example.com のサーバは、この Cookie は自分が設定したものと誤認する可能性もある。ウェブブラウザのこのような挙動を使えば、foo.example.com のサーバから bar.example.com に対して何らかの攻撃が可能になるかもしれない。)

JVN

[HOME](#)
[JVNとは](#)
[脆弱性レポートの読み方](#)
[脆弱性レポート一覧](#)
[VN-JP](#)
[VN-JP \(連絡不能\)](#)
[VN-VU](#)
[TA](#)
[TRnotes](#)
[JVN iMedia](#)
[脆弱性情報データベース](#)
[MyJVN](#)
[JVNJIS/RSS](#)
[ペンダ情報一覧](#)
[連絡不能関係者一覧](#)
[脆弱性情報の届出](#)
[お問合せ先](#)

GOOGLE根据我们的论文修改浏览器



ISC 互联网安全大会



360 互联网安全中心

Tracker Project: chromium Issues People Development process History Sign in

New issue Search Open issues for Search Advanced search Search tips

Issue 522261 Measure percentage of cookies that are Secure and set/overwritten by HTTP URLs

Starred by 2 users Project Member Reported by est...@chromium.org, Aug 18, 2015 Back to list

Status: Fixed
Owner: est...@chromium.org
Closed: Aug 2015
Cc: mkwst@chromium.org
Components: Internals>Network>Cookies Security
OS: All
Pri: 2
Type: Feature

Sign in to add a comment

As suggested in <https://www.usenix.org/conference/usenixsecurity15/technical-sessions/presentation/zheng>, we can investigate how frequently HTTP URLs set or overwrite Secure cookies, with the hopes that it's sufficiently low that we might be able to disable this functionality.

Project Member Comment 1 by bugdroid1@chromium.org, Aug 21, 2015

The following revision refers to this bug:
<https://chromium.googlesource.com/chromium/src.git/+bd99e6be869fd6caff8a0f676d1357dacdbc7532>

commit bd99e6be869fd6caff8a0f676d1357dacdbc7532
Author: estark <estark@chromium.org>
Date: Fri Aug 21 21:31:17 2015

Move cookie source display logic to CookiesTreeModel

Previously, CanonicalCookie::Source() returned the source of the cookie as needed by CookiesTreeModel -- that is, with the port stripped and scheme changed to http. This CL moves this CookiesTreeModel-specific logic to CookiesTreeModel, so that CanonicalCookie::Source() represents the actual origin that set the cookie.

This CL is to be followed up with <https://codereview.chromium.org/1303593002/>, which aims to measure the frequency of non-secure origins setting Secure cookies.

BUG=~~522261~~
TBR=miguelg@chromium.org

Review URL: <https://codereview.chromium.org/1297023004>

Cr-Commit-Position: refs/heads/master@{#344866}

[modify] <http://crrev.com/bd99e6be869fd6caff8a0f676d1357dacdbc7532/chrome/browser/android/cookies/c>

As suggested in our USENIX paper, Google can investigate how frequently HTTP URLs set or overwrite secure cookies, with the hops that ... to disable this functionality.

GOOGLE 根据我们的论文提议修改国际标准



HTTPbis
Internet-Draft
Updates: [6265](#) (if approved)
Intended status: Standards Track
Expires: April 10, 2016

M. West
Google, Inc
October 8, 2015

Deprecate modification of 'secure' cookies from non-secure origins draft-west-leave-secure-cookies-alone-01

Abstract

This document updates [RFC6265](#) by removing the ability for a non-secure origin to set cookies with a 'secure' flag, and to overwrite cookies whose 'secure' flag is set. This deprecation improves the isolation between HTTP and HTTPS origins, and reduces the risk of malicious interference.

5.2. Informative References

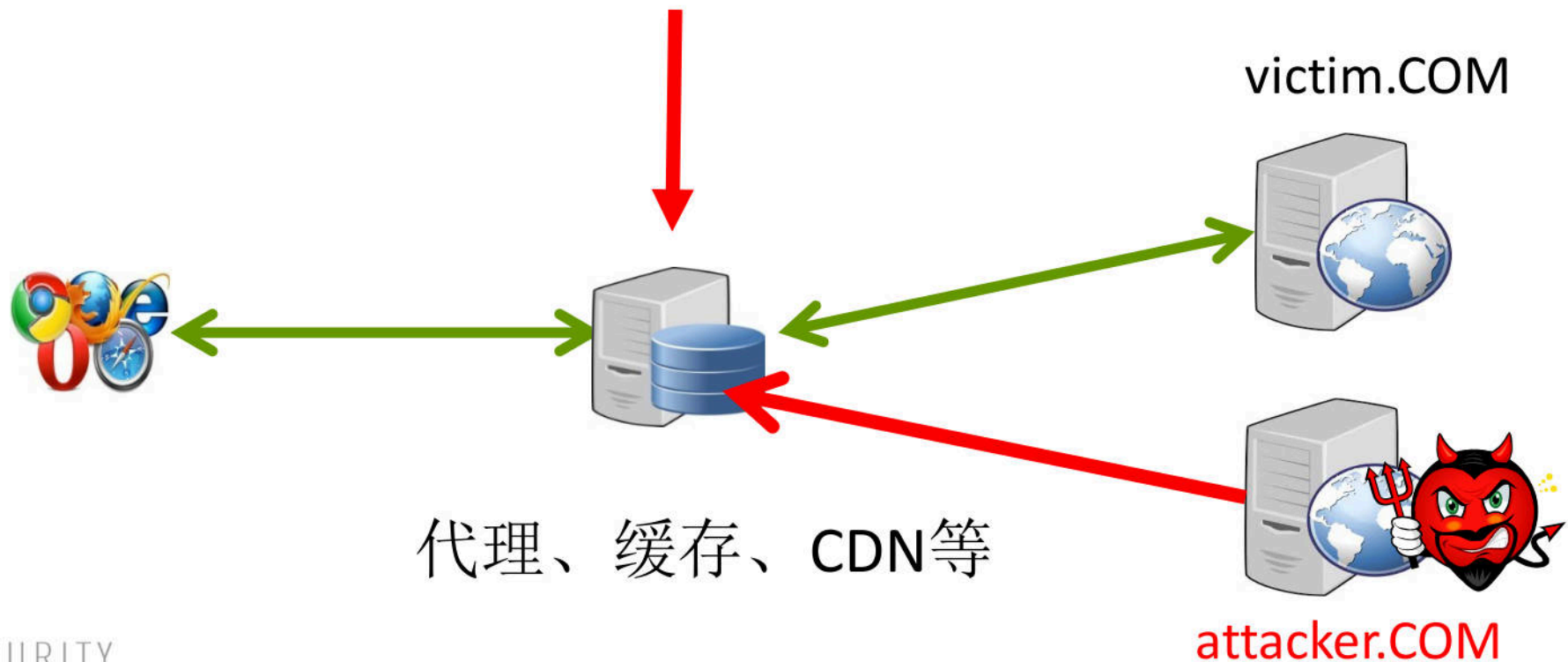
[COOKIE-INTEGRITY]

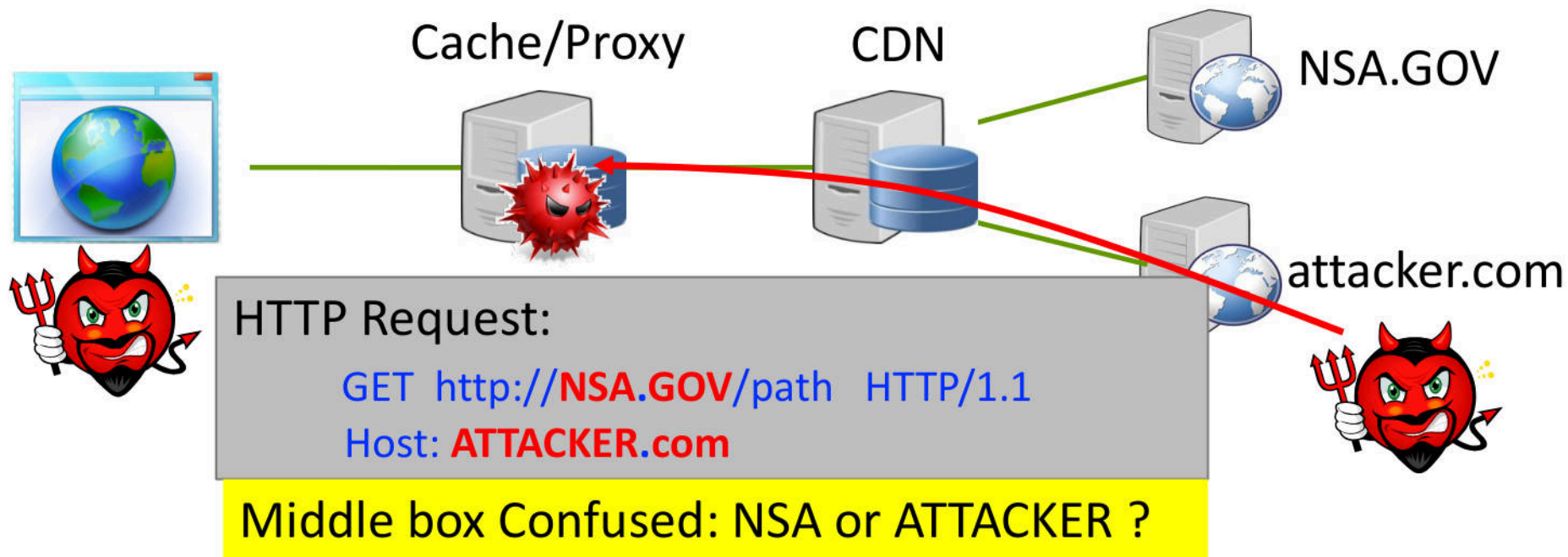
Zheng, X., Jiang, J., Liang, J., Duan, H., Chen, S., Wan, T., and N. Weaver, "Cookies Lack Integrity: Real-World Implications", n.d., <<https://www.usenix.org/system/files/conference/usenixsecurity15/sec15-paper-zheng.pdf>>.

NDSS'16 优秀论文的Idea是怎样产生的?

- 由Cookie 被覆盖想到的:

中间设备（缓存、代理、CDN）同时作为客户端和服务端，如何防止缓存不被攻击者覆盖呢？





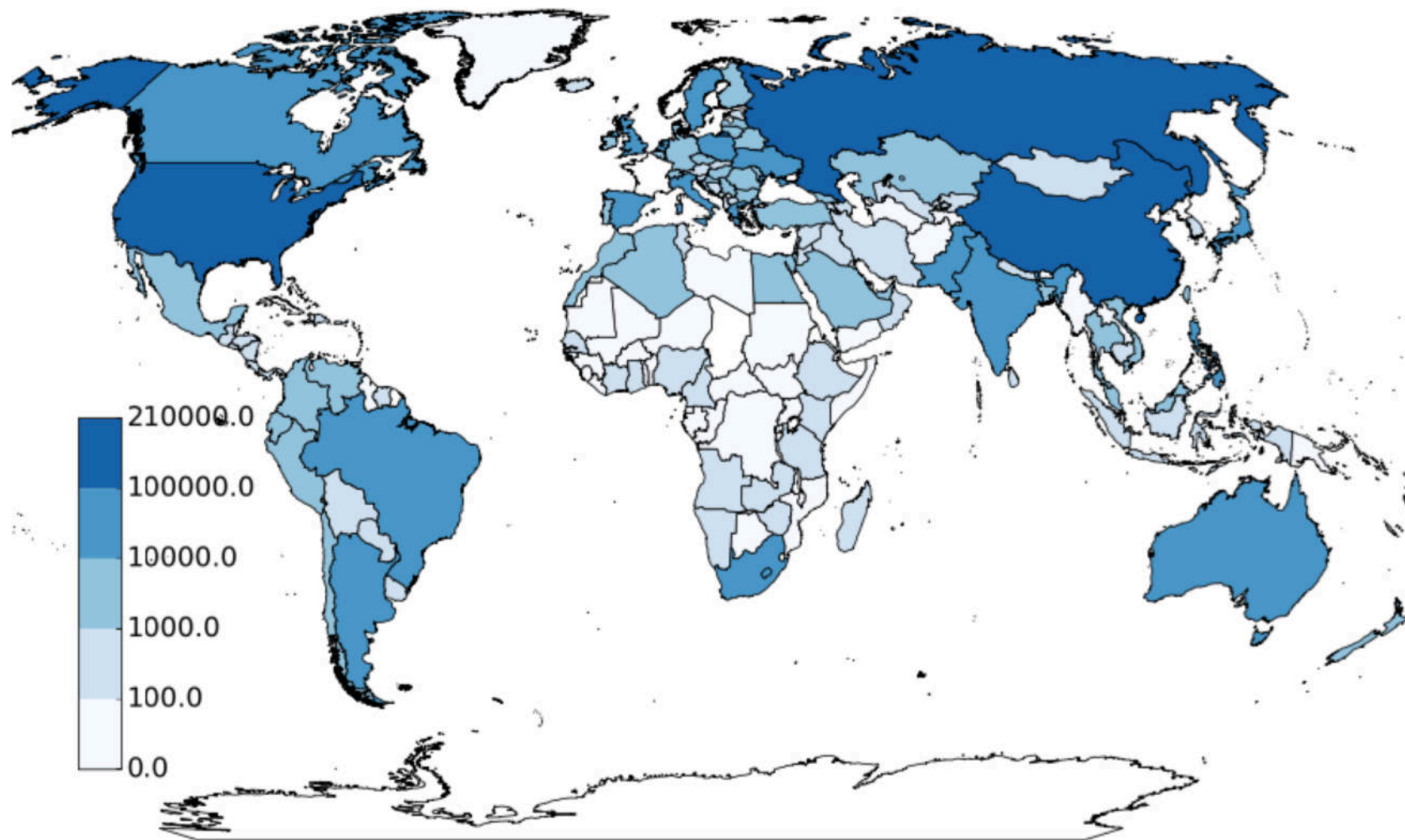
影响到的产品/系统



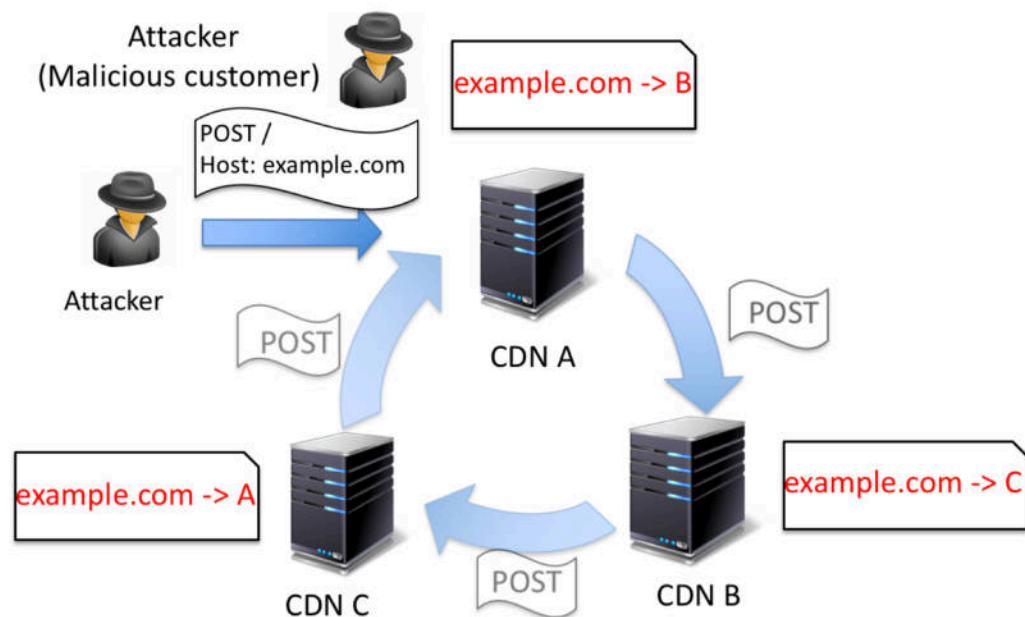
演示：我们如何“攻破”美国NSA网站



98% 缓存服务器可能受到攻击



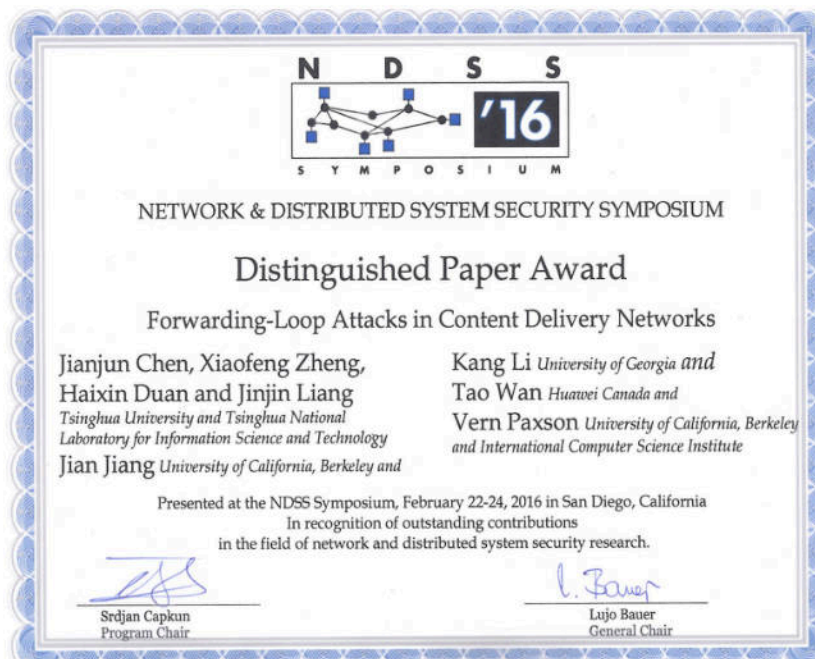
一个意外的发现：CDN转发循环攻击



利用内容分发网络(CDN)设计漏洞构造无限的转发循环，可大量消耗CDN资源甚至拒绝服务，可能导致互联网的瘫痪



证实为可被攻击的厂商



美国日本等政府应急响应组织安全公告



Vulnerability Notes Database

Advisory and mitigation information about software vulnerabilities

[DATABASE HOME](#)[SEARCH](#)[REPORT A VULNERABILITY](#)[HELP](#)

Vulnerability Note VU#938151

Forwarding Loop Attacks in Content Delivery Networks may res
service

Original Release date: 29 Feb 2016 | Last revised: 04 Mar 2016



Print



Tweet



Send



Share

Overview

Content Delivery Networks (CDNs) may in some scenarios be manipulated into a forwarding loop server resources and causes a denial of service (DoS) on the network.

Description

CWE-400: Uncontrolled Resource Consumption ('Resource Exhaustion')



公開日：2016/03/01 最終更新日：2016/03/01

JVNVU#94080110

コンテンツデリバリネットワーク (CDN) に対するサ
ービス運用妨害 (DoS) の問題 (Forwarding Loop 攻
撃)

概要

コンテンツデリバリネットワーク (CDN) に対する攻撃手法として、Forwarding L
させサービス運用妨害 (DoS) 状態にする攻撃 (Forwarding Loop 攻撃) が指摘さ

影響を受けるシステム

- コンテンツデリバリネットワーク (CDN) サービス

詳細情報

無制限なリソースの消費 (リソース枯渇) (CWE-400)

コンテンツデリバリネットワーク (CDN) は、コンテンツへのアクセスリクエスト
いサーバに転送して処理することで、ウェブサイトの処理効率とスケーラビリティ

我们相信你们所指出的攻击是对CDN和整个Internet的
严重威胁，
你们能否协调不同CDN的交流和沟通

On Mon, Oct 26, 2015 at 2:34 PM, Amir Khakpour <amir.khakpour@verizon.com> wrote:

Hi Haixin/Jianjun,

My name is Amir, and I work in Verizon Digital Media Services (formerly iCast). As you might know, we are one of the major CDNs in the world.

One of our clients shared your paper with us to assess if we are vulnerable to loop-forwarding attacks you described in your paper.

First of all, we wanted to congratulate you on the great work and nicely written and technically detailed paper. We believe the attacks you mentioned are valid and can be a great danger to CDNs and Internet in general. This is indeed something we take very seriously.

Secondly, we agree with you that the most effective way to defend such attack is what you have called "Unifying and standardizing loop-detection header" in the paper. We wonder if you are willing to coordinate the effort of communicating with different CDNs to disallow their customers from tampering with and/or removing "via", "forwarded", and "X-forwarded-for" headers. This would indeed help CDNs to avoid multi-CDN and Dam flooding attacks. This can be easily verifiable by a third-party such as you (or academia, in general) as a follow-up work.

Please let us know if any help on your side is needed.

Also, if you are willing to chat about this matter, please let us know your convenient time and we can schedule a meeting.

Thanks,

Amir R. Khakpour, PhD
Senior Research Scientist
Verizon Digital Media Services

目录



ISC 互联网安全大会



360 互联网安全中心

- 自由探索与开放合作的经历
- 几个学术研究的案例
- ▶ 研究方法和创新的体会

创新研究的思路（没有固定的套路）

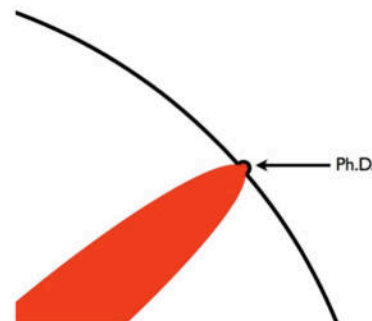
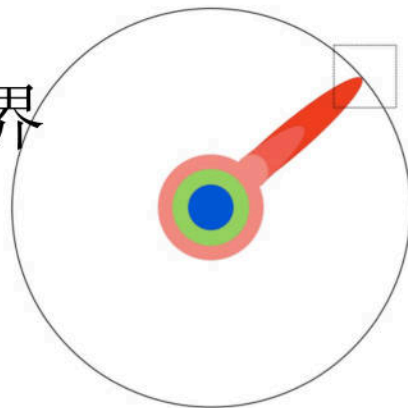
- 找到一个新的研究问题
 - 大量的阅读
 - 大量的实践
 - 广泛的学术交流
- 用简单的逻辑说明问题
 - 漏洞的原因
 - 利用的方法
 - 攻击的后果
- 大规模的实验
 - 协议规范的分析
 - 开源代码分析
 - 现实系统的黑盒测试
- 对抗思维
 - 对于攻击，考虑如何防范
 - 对于防范方法，考虑如何攻击、逃逸
- 负责的披露
 - 与工业界一起探讨解决方案

- 最基本科学方法
 - 逻辑的方法：不一定用数学、符号，目的是为了让人看懂
 - 实证的方法：大样本的实验
- 创新，并且证明自己的创新
 - 为什么需要相关工作、文献阅读
 - 问题创新：所提出的问题别人没有研究过
 - 方法的创新：要证明自己所提出的方法比别人好
- 学术道德
 - 遵守法律、学术道德
 - 负责任的披露、不能攻击对现有系统、个人隐私

研究的体会

- 带领学生找到国际学术研究的前沿

人类知识的边界



- 和学生相互启发，向学生学习
- 发现学生好的创意，创造条件和环境
- 国际视野：关注全球问题

- 开放、自由的环境里，更容易创新
- 科学的方法
 - 逻辑、实证
- 站在世界学术的前沿，关注世界性的问题
- 教师不是把篮子填满，而是把火把点燃



ISC 互联网安全大会



360 互联网安全中心

谢谢!

2018 ISC 互联网安全大会 中国·北京

Internet Security Conference 2018 Beijing·China

(原中国互联网安全大会)